MODULE 35 · DOMAIN 4 - OPERATING, MONITORING, SECURING

Network isolation and encryption

VPC mode, network isolation, endpoints, and encryption at rest and in transit.

MODULE 35 of 43 DOMAIN 4 - Monitoring WEIGHT 24%

admin@sthithapragna.com

VPC mode decides where the job sits. **Network isolation** decides whether it can talk.

What NetworkConfig actually contains

SETTING	WHAT IT DOES
`VpcConfig`	Subnets and security groups. Puts the job's interfaces in your VPC
`EnableNetworkIsolation`	Whether the container may make inbound or outbound network calls
`EnableInterContainerTrafficEncryption`	Encrypts communication between instances in a distributed job

ON THE EXAM

Three booleans and a VPC. Most network questions in this domain are asking which of these three the scenario needs.

VPC mode

- The job's network interfaces are created in **your subnets**, with **your security groups**.
- So traffic is subject to your routing, your endpoints and your network controls.
- That is how a job reaches a private database, or an on-premises system over Direct Connect.
- **It also means the job needs a route to whatever it depends on**: S3, ECR, CloudWatch.
- Without that route, the job fails early with nothing logged. Module 31's diagnostic.

> ON THE EXAM
>
> VPC mode does not make a job private by itself. It makes the job subject to your network design, for better and worse.

Network isolation

- **The container is restricted from making any outbound network calls.** None at all.
- SageMaker AI still **stages input data in and output data out** for it.
- So the job can train on your data and cannot exfiltrate it, or fetch anything unexpected.
- That is the control a regulator usually wants when third-party code touches sensitive data.
- It is also a Security Hub control for hosted models, not just for training.

> ON THE EXAM
>
> This is the strongest data-exfiltration control available for a container. The container cannot phone home, because it cannot phone anything.

What network isolation breaks

- **No pip install at runtime.** Dependencies must be baked into the image.
- **No calls to a third-party API** from inside the container, for any reason.
- **No downloading a pretrained model** from an external hub at job start.
- **No custom S3 reads from inside your script.** Only what SageMaker AI staged for you.
- Every one of those is a common pattern, so enabling it usually requires changing the code.

> ON THE EXAM
>
> The failure is often confusing: the job starts, then hangs or fails on a call the script has always made without anyone noticing.

VPC mode or network isolation?

VPC MODE, WHEN

The job needs your network

- It must reach a private database or system.
- Traffic must follow your routing and controls.
- You want endpoints rather than public paths.
- It still makes outbound calls, within your VPC.

NETWORK ISOLATION, WHEN

The job must reach nothing

- Third-party code touches sensitive data.
- Exfiltration is the stated concern.
- Everything needed is in the image and the input.
- No outbound calls at all, anywhere.

THE TIEBREAKER

They compose. A regulated workload frequently wants both: inside your VPC, and unable to call out of it.

Inter-container traffic encryption

- Encrypts all communication **between instances** in a distributed job.
- AWS states the trade-off: it gives greater security, and **the processing might take longer**.
- Distributed training exchanges **gradients and weights**, not usually the dataset itself.
- For a highly sensitive model, those weights are the asset worth protecting.
- On a single-instance job there is no inter-container traffic, so it changes nothing.

> ON THE EXAM
>
> This is the one with a documented performance cost. Enable it where the requirement says to, not everywhere by default.

VPC endpoints and PrivateLink

- An **interface endpoint** puts a private entry point to an AWS service inside your subnet.
- Traffic reaches the service **without traversing the public internet**, over PrivateLink.
- A **gateway endpoint** serves S3 and DynamoDB through a route table entry instead.
- Endpoint policies can restrict what may be reached through that endpoint.
- **Without endpoints, a private subnet needs a NAT gateway**, which costs per hour and per GB. Module 32.

> ON THE EXAM
>
> Endpoints are a security control and a cost control at once, which makes them one of the easier arguments to win.

Reaching on-premises systems

- **Direct Connect** or a **Site-to-Site VPN** connects your VPC to an on-premises network.
- So a training job in VPC mode can read from a database that never touches the internet.
- This is frequently the reason VPC mode is required at all.
- Bandwidth and latency become real constraints on how training data gets staged.
- Often the better pattern is landing data in S3 first, then training from there. Module 02.

ON THE EXAM

Reading training data across a VPN for every epoch is a design people try once. Stage it in S3 instead.

Endpoints an ML VPC usually needs

SERVICE	WHY THE JOB NEEDS IT
S3	Input data, model artefacts, checkpoints, output
SageMaker AI API and Runtime	Creating jobs, and invoking endpoints
ECR API and ECR DKR	Pulling the container image. Both are needed
CloudWatch Logs	Writing logs. Without it, logs simply do not appear
STS	Assuming roles
KMS	Decrypting encrypted data and volumes
Bedrock	If the workload calls foundation models from the VPC

ON THE EXAM

The ECR row catches people: pulling an image needs both the API endpoint and the DKR endpoint, and missing one fails before any logging.

Security groups and endpoint policies

- The job's **security group** controls what it may reach, and what may reach it.
- An interface endpoint has its own security group, which must accept traffic from the job's.
- **A missing rule between those two groups** is a very common cause of an unexplained hang.
- Distributed training needs the security group to allow **traffic to itself**, between instances.
- **aws:SourceVpce** from module 34 restricts a service to calls arriving through your endpoint.

> ON THE EXAM
>
> Two security groups must agree, exactly as two policies must in module 34. Half an agreement produces a timeout rather than an error.

Endpoint policies

- A **VPC endpoint policy** restricts what may be reached **through that endpoint**.
- So an S3 endpoint can permit only **your** buckets, not every bucket in AWS.
- Without that, an endpoint is a private path to **all of S3**, including somebody else's bucket.
- That closes a real exfiltration route: a private subnet with a wide-open S3 endpoint.
- Combine with aws:SourceVpce on the bucket side, from module 34, for both directions.

> ON THE EXAM
>
> An endpoint without a policy solves the internet problem and leaves the data-movement problem entirely open.

Private Docker registries

- A model can pull its image from a **private Docker registry inside your VPC**.
- So images are accessed **through VPC endpoints, without traversing the public internet**.
- That reduces supply-chain and image-tampering risk, which is why it is a Security Hub control.
- The control fails when **repository access mode is set to platform** rather than VPC.
- It applies to **multi-container inference pipelines** too, from module 21.

> ON THE EXAM
>
> Module 21's container image pinning was about reproducibility. This is the same artefact, viewed as a supply-chain risk.

Notebook internet access is immutable

- **A notebook instance's internet access setting cannot be changed after creation.**
- So getting it wrong means recreating the instance, and losing anything stored locally.
- Direct internet access is convenient and is what a security review will object to.
- Disabling it means the notebook depends on your endpoints, exactly like a job does.
- Studio configuration is set at the domain level, and is a similarly early decision.

ON THE EXAM

One of a small number of genuinely immutable settings in SageMaker AI. Worth knowing before somebody creates twenty notebooks.

Studio network modes

- A Studio domain is created in one of two network modes, chosen **at domain creation**.
- **Public internet only** routes Studio traffic through an AWS-managed network. Easy, and not private.
- **VPC only** routes everything through your subnets, so it needs your endpoints.
- In VPC-only mode, **everything Studio does needs a path**: package installs, Git, image pulls.
- That is usually where a team first meets this module's principle, painfully.

> ON THE EXAM
>
> VPC-only is the answer a security review wants and the configuration that breaks the most workflows on day one.

Egress filtering

- **AWS Network Firewall** can inspect and filter traffic leaving your subnets.
- So a workload can reach an approved package repository and **nothing else**.
- That is the middle ground between full internet access and network isolation.
- Domain allow-lists are the usual pattern, rather than enumerating what to block.
- It is infrastructure to run and maintain, so it earns its place at organisation scale.

> ON THE EXAM
>
> Isolation is binary; a firewall is not. When a team genuinely needs one external dependency, this is how they get exactly one.

VPC Flow Logs

- **Flow Logs** record accepted and rejected traffic at the interface, subnet or VPC level.
- **Rejected entries are the useful ones** when a job hangs: they name what it tried to reach.
- That turns a silent timeout into a specific missing endpoint or security group rule.
- They go to CloudWatch Logs or S3, and can be queried with Logs Insights. Module 31.
- They are a cost line at volume, so scope them rather than enabling everything everywhere.

> ON THE EXAM
>
> A hanging job in a private subnet gives you nothing. Flow Logs turn that silence into a destination and a port.

Network controls decide **where data goes**. Encryption decides **who can read it** when it gets there.

What gets encrypted, and where

STORE	WHAT TO SET
S3 data and artefacts	Bucket encryption, ideally with a customer-managed KMS key
Training and processing volumes	VolumeKmsKeyId on the job
Endpoint storage volumes	KmsKeyId on the endpoint configuration
Studio home directories	EFS encryption with a KMS key
Notebook instance volumes	EBS encryption with a KMS key
Feature Store offline store	KMS key on the S3 storage. A Security Hub control
Feature Store online store	Customer-managed KMS key supported

ON THE EXAM

Seven places, and each is configured separately. Encrypting the bucket does not encrypt the training volume.

Finding sensitive data

- **Amazon Macie** discovers and classifies sensitive data in S3, including personal data.
- That answers module 08's question directly: **is there personal data in this training set?**
- Useful before training, and useful on **captured inference data**, which nobody classified.
- Findings can drive automated action, such as quarantining a bucket.
- Data arriving from a new source is the case worth scanning. Assumptions age badly.

ON THE EXAM

Module 30's invocation logs and module 20's data capture create S3 objects full of user input that nobody ever classified.

AWS-managed or customer-managed keys

- **AWS-managed keys** encrypt by default with no configuration and no key policy to write.
- **Customer-managed keys** give you the key policy, rotation control, and the ability to revoke.
- A compliance requirement usually means customer-managed, because control is the point.
- **Deleting or disabling a key makes the data unreadable**, which is both the feature and the risk.
- Key policies are resource policies, so module 34's two-sided rule applies.

> ON THE EXAM
>
> The ability to revoke access by disabling a key is exactly why regulators ask for customer-managed keys.

Protecting model artefacts

- A trained model is **intellectual property** and a compressed form of your training data.
- So the artefact bucket deserves the same encryption and access control as the data. Module 34.
- **Model inversion and membership inference** are real attacks against a model people can query.
- An endpoint returning full confidence scores gives an attacker more to work with than a label.
- Rate limiting and returning less detail are the practical mitigations.

> ON THE EXAM
>
> Teams protect the training data carefully and leave the model artefact in a bucket with default permissions. The model encodes the data.

Backup and recovery for ML

- **S3 versioning** on artefact and data buckets protects against an overwrite or a bad delete.
- The **Model Registry** is your rollback path, from module 24. Protect it accordingly.
- **A retention policy that prunes old model versions removes your rollback**, as module 24 warned.
- Pipelines and configuration live in code, so a repository is part of the recovery story.
- Ask what you would need to rebuild an endpoint from nothing, and check you still have it.

> ON THE EXAM
>
> Recovery for ML is unusual: you need the artefact, the image, the configuration and the data version together, or you have none of it.

When IAM allows and KMS denies

- **A KMS key policy can deny what an IAM policy allows.** Both must permit the operation.
- So a job with full S3 access still cannot read encrypted objects without key permissions.
- The execution role needs **kms:Decrypt**, and often **GenerateDataKey** for writing.
- The key policy must name the role, or delegate to IAM policies in the account.
- Cross-account encrypted data needs the key policy to permit the other account too. Module 34.

> ON THE EXAM
>
> This is the commonest encryption failure in ML: the bucket policy is right, the IAM policy is right, and the key says no.

Encryption on the wire

- **All AWS API calls use TLS.** Calls to SageMaker AI and Bedrock are encrypted by default.
- Endpoint invocations are over HTTPS, and a VPC endpoint keeps them off the public internet.
- **Inter-container traffic is the exception**, and is only encrypted if you enable it.
- Traffic between your application and your VPC depends on your own architecture.
- 'Encrypt data in transit' as a requirement usually means the third bullet, since the rest already is.

> ON THE EXAM
>
> The useful answer to an in-transit requirement is usually inter-container encryption plus VPC endpoints, because TLS is already there.

Network controls for Bedrock

- A **VPC interface endpoint for Bedrock** keeps model calls off the public internet.
- Combined with **aws:SourceVpce**, you can require that all Bedrock calls come through it.
- Knowledge Base data lives in **your** vector store and **your** S3, under your encryption.
- Model invocation logs from module 30 contain prompts, so they need the same protection as the data.
- Residency from module 08 still constrains which Regions may be used at all.

> ON THE EXAM
>
> The retrieval corpus and the invocation logs are the sensitive stores in a Bedrock application. The model itself holds nothing of yours.

Residency in practice

- A residency requirement constrains **which Regions** may hold or process the data.
- It reaches further than people expect: **logs, backups, traces and model artefacts** all count.
- Cross-Region inference profiles move inference across a geography, which may not be permitted. Module 25.
- **SCPs can deny non-approved Regions outright**, which beats a policy document. Module 34.
- And a Region that satisfies residency may not offer the model you wanted. Module 25.

> ON THE EXAM
>
> Residency is the constraint that outranks architecture. It is also the one most often discovered after the design is finished.

Secrets Manager and Parameter Store

- **Secrets Manager** stores credentials, encrypts them with KMS, and can rotate them automatically.
- **Parameter Store** handles configuration, with SecureString for simpler secret cases.
- A job in a private subnet needs a **VPC endpoint** to reach either of them.
- That is another quiet cause of a job hanging: the secret fetch has nowhere to go.
- Scope the execution role to **one secret**, from module 34.

> ON THE EXAM
>
> Every service a container calls needs a path. Secrets Manager is the one people forget when they lock down a subnet.

Evidence an auditor asks for

QUESTION	WHERE THE EVIDENCE IS
Is data encrypted at rest?	KMS key configuration, and Security Hub controls
Can the container reach the internet?	The job's EnableNetworkIsolation setting
Who accessed this data?	CloudTrail, plus S3 access logging. Module 31
Where does this data live?	Region configuration, and an SCP denying others
Who approved this model?	The Model Registry approval record. Modules 21 and 34
Is this configuration enforced?	Infrastructure as code, plus Config rules

ON THE EXAM

The last row separates a control from an intention: something must detect drift, or the evidence is a screenshot from March.

Requirement to control

WHAT THE SCENARIO ASKS FOR	THE CONTROL
Container must not reach the internet	EnableNetworkIsolation
Job must reach a private database	VpcConfig, with subnets and security groups
Traffic must not traverse the public internet	VPC endpoints and PrivateLink
Encrypt communication between training instances	EnableInterContainerTrafficEncryption
We must be able to revoke access to the data	A customer-managed KMS key
Images must come from a trusted source	Private Docker registry in the VPC
All Bedrock calls from our network only	Bedrock VPC endpoint, plus aws:SourceVpce

ON THE EXAM

Rows one and two are the pair the exam most often mixes. Read for 'must not reach out' versus 'must reach in'.

Testing the isolation

- Run a job that **deliberately tries** to reach the internet, and confirm it cannot.
- An isolation control nobody has tested is an assumption, exactly like module 24's untested alarm.
- Check **Flow Logs** for the rejection, so you have evidence rather than an absence.
- Test the legitimate paths too: can it reach S3, ECR and CloudWatch as intended?
- Retest after network changes. A new route or endpoint can open a path nobody intended.

> ON THE EXAM
>
> Same discipline as module 24's gate and module 32's rollback: the control you have never seen work is the one that will not.

Symptoms, and what they usually mean

SYMPTOM	USUAL CAUSE
Job fails immediately, no logs, after adding VPC config	No route to S3, ECR or CloudWatch. Add endpoints
Image pull fails in a private subnet	Missing one of the two ECR endpoints
No logs at all from a VPC job	No CloudWatch Logs endpoint. The logs cannot leave
Script hangs installing packages	Network isolation is on. Bake dependencies into the image
Job reads the bucket but not the objects	KMS key policy does not permit the execution role
Distributed training will not start	Security group does not allow traffic to itself
Cannot change notebook internet access	Immutable after creation. Recreate the instance

ON THE EXAM

Row three is neat and cruel: without a logs endpoint, the very thing you would use to debug the problem is what is missing.

The network setup to decide early

DECISION	WHY IT CANNOT WAIT
Studio domain network mode	Set at domain creation. Changing it means a new domain
Notebook internet access	Immutable after creation
VPC endpoints for the dependency list	Every one missing looks like the same failure
KMS keys and their policies	Retrofitting encryption means re-encrypting everything
Flow Logs	Without them, a private-subnet failure is silent
Region choice	Residency and model availability both depend on it

ON THE EXAM

Two of these six are literally immutable, and the rest are painful to change once anything depends on them.

Isolating a job means giving it a path to everything it legitimately needs, first.

A training job that ran successfully for months is moved into a private subnet with VpcConfig, to satisfy a new security standard. It now fails about ninety seconds after starting.

There are no log streams for the job in CloudWatch at all. The execution role and the S3 paths are unchanged.

What is the most likely cause?

A Network isolation was enabled at the same time, blocking the container

B The subnet has no route to the services the job needs. Add VPC endpoints

C The execution role lost its S3 permissions when the VPC was attached

D Inter-container traffic encryption is incompatible with private subnets

◆ PAUSE AND DECIDE

What is the most likely cause?

A. Network isolation was enabled at the same time, blocking the container

Possible, and the scenario says only VpcConfig was added. Network isolation is a separate setting, which is the distinction being tested.

B. The subnet has no route to the services the job needs. Add VPC endpoints

A private subnet has no path to S3, ECR or CloudWatch without endpoints or NAT. The job fails before printing anything, which is exactly no logs.

C. The execution role lost its S3 permissions when the VPC was attached

Attaching a VPC does not modify IAM. The scenario states the role is unchanged.

D. Inter-container traffic encryption is incompatible with private subnets

Invented. It encrypts traffic between instances and has nothing to do with subnet routing.

THE SIGNAL

Module 31's diagnostic: no logs means the failure preceded the container printing anything, and a missing network path is one of its four causes.

> A bank wants to train on customer data using a third-party algorithm container supplied by a vendor. Their regulator requires assurance that the container cannot transmit data anywhere.
>
> The container image already includes all its dependencies. Input and output are ordinary S3 paths.

What should they configure?

A. A private subnet with no NAT gateway, and VPC endpoints for S3 only

B. Inter-container traffic encryption on the training job

C. A customer-managed KMS key on the training volume

D. EnableNetworkIsolation on the training job

◆ PAUSE AND DECIDE

What should they configure?

A — A private subnet with no NAT gateway, and VPC endpoints for S3 only

A reasonable layer, and the container can still reach whatever those endpoints permit. It restricts the destination rather than forbidding calls.

B — Inter-container traffic encryption on the training job

Encrypts traffic between instances in a distributed job. It does not stop a container calling out.

C — A customer-managed KMS key on the training volume

Protects data at rest on the volume. It does nothing about what the container transmits.

D — EnableNetworkIsolation on the training job

The container is restricted from making any outbound calls, while SageMaker AI still stages input and output. Exactly the assurance the regulator asked for.

THE SIGNAL

The enabling detail is that the image already has its dependencies. Without that, isolation would break the job.

> After a security review, a team enables network isolation on all training jobs. One job now hangs for several minutes and then fails. Its training script begins by installing two packages with pip and downloading a tokenizer from a public model hub.
>
> The team asks whether network isolation is broken.

What should you tell them?

A. It is broken. Open a support case, since isolation should not block package installs

B. Add a NAT gateway so the container can reach the internet while isolated

C. It is working. Bake the packages and the tokenizer into the container image

D. Disable isolation for that job, since it needs external dependencies

◆ PAUSE AND DECIDE

What should you tell them?

A It is broken. Open a support case, since isolation should not block package installs

Blocking outbound calls is precisely what the setting does. A package install is an outbound call.

B Add a NAT gateway so the container can reach the internet while isolated

Network isolation blocks the container regardless of routing. A NAT gateway would cost money and change nothing.

C It is working. Bake the packages and the tokenizer into the container image

The symptom is the control functioning. Baking dependencies in removes the runtime fetch and also makes the job reproducible.

D Disable isolation for that job, since it needs external dependencies

Abandons the security requirement to preserve a habit. The dependency can move into the image instead.

THE SIGNAL

A runtime download is also a reproducibility problem from module 14: the job depends on an external service being up and unchanged.

> A processing job can list objects in an S3 bucket but fails when reading them. The bucket is encrypted with a customer-managed KMS key. The execution role has full S3 permissions on that bucket, and the bucket policy permits the role.
>
> VPC endpoints for S3 and KMS both exist and are reachable.

What is missing?

A. kms:Decrypt for the execution role, permitted by both its IAM policy and the key policy

B. A gateway endpoint for S3, since the interface endpoint does not support GetObject

C. Network isolation, which is required for encrypted data access

D. s3:GetObject on the bucket policy, which only grants ListBucket

◆ PAUSE AND DECIDE

What is missing?

A kms:Decrypt for the execution role, permitted by both its IAM policy and the key policy

Listing needs no decryption; reading does. A KMS key policy can deny what an IAM policy allows, so both sides must permit the role.

B A gateway endpoint for S3, since the interface endpoint does not support GetObject

Invented limitation. The scenario also states the S3 endpoint exists and is reachable.

C Network isolation, which is required for encrypted data access

Backwards. Network isolation restricts outbound calls and has no relationship to decryption.

D s3:GetObject on the bucket policy, which only grants ListBucket

The scenario states the role has full S3 permissions and the bucket policy permits it. The failure is on the object contents, not the API.

THE SIGNAL

List works and read fails is the signature. Listing returns metadata and needs no key; reading returns content and does.

What to take from this module

- **VPC mode places the job. Network isolation silences it.** Different settings, and they compose.
- **Network isolation blocks pip, model hubs and third-party APIs.** Bake it into the image.
- **A private subnet needs endpoints** for S3, both ECR endpoints, CloudWatch Logs, STS and KMS.
- **A KMS key policy can deny what IAM allows.** List works, read fails.
- **Inter-container encryption is the one with a documented performance cost.**

> ON THE EXAM
>
> Module 36 closes the security run with Guardrails, responsible AI and securing the pipeline itself.